

Learning Sequential SQL Injection Payload Mutation Strategies via Reinforcement Learning Approach for Efficient Web Application Firewall Evasion

Roby Firnando Yusuf*, Motchas**, and Sunoh Choi***

지원기관표기

Abstract

With the explosively increasing online data, recommender systems are more and more important. Therefore, increasing e-commerce data presents new challenges for storing and querying large amounts of data to online recommendation systems. However, there are few researches about processing a lot of online data in order to improve the performance of large-scale recommendation systems. This paper proposes a new graph data storage model for the large-scale recommendation system. In addition, the proposed graph data storage model includes new type of the index in order to rapidly compose recommendation lists. Also, we perform comparison experiments with existing data model. And we prove that our distributed graph data model has better performance with large-scale recommendation systems than other data models like the relational data model.

Keywords

distributed graph database, recommender systems, collaborative filtering, cloud computing

* 00대학교 00과

- ORCID: <https://orcid.org->

(클릭하면 사이트로 이동됨)에서 등록후 가입

** 00대학교 00학과 교수(교신저자)

- ORCID:

• Received: 00 17, 2024, Revised: 00 20, 2024, Accepted: 00 15, 2025

• Corresponding Author: 00

Dept. of

Korea

Tel.: + , Email: 0000

1. INTRODUCTION

Web applications remain central to modern digital infrastructure, supporting financial, healthcare, and cloud-based services. Despite long-standing defensive practices, injection vulnerabilities remain a major web security risk. In the OWASP Top 10:2025, Injection is listed as A05; OWASP reports that 100% of applications were tested for some form of injection and that this category contains 37 mapped Common Weakness Enumerations (CWEs) [1]. SQL injection remains one of the notable injection weaknesses because user-controlled input may be interpreted as part of backend queries when validation, filtering, or parameterization is insufficient [1]. Its detection is further complicated by SQL's syntactic flexibility, where semantically similar queries can be represented through different keyword casing, comments, encodings, whitespace variants, and token fragmentation.

Web Application Firewalls (WAFs) and application-layer filters mitigate SQL injection by blocking suspicious request patterns. However, these defenses often rely on signatures, rule sets, token patterns, or lightweight detection models rather than full semantic interpretation of database queries. This creates an evasion surface in which malicious payloads can be transformed while preserving their intended SQL semantics. WAF-A-MoLE demonstrates this setting through mutation operators that alter SQL injection payload syntax without changing malicious semantics [2].

Prior work has explored SQL injection detection using machine-learning and deep-learning techniques. SQLiGoT represents SQL queries as graphs of tokens and applies SVM-based classification for SQL injection detection [3]. Ensemble-based models classify

SQL injection attack levels using regex-derived and statistical features [4], while LSTM-based detection learns contextual patterns from SQL query strings [5]. These approaches improve static detection performance, but they evaluate payloads as isolated inputs rather than as products of an adaptive mutation process.

Recent adversarial and reinforcement-learning approaches move beyond static detection. SSQLi proposes a black-box adversarial SQL injection method based on reinforcement learning, using a state-vector representation algorithm, an attack-strategy matrix, and a Soft Actor-Critic agent to generate adversarial SQL injection examples [6]. SQIRL applies deep reinforcement learning with multiple worker agents and grey-box feedback to detect SQL injection vulnerabilities through targeted fuzzing [7]. These studies show that automated payload transformation and reinforcement-learning-guided testing can improve SQL injection security evaluation. However, existing approaches provide limited explicit analysis of how mutation ordering affects WAF evasion. Applying multiple transformations is not necessarily equivalent to learning an effective mutation sequence, because the success of an action may depend on the current payload state produced by previous actions.

This study proposes SeqSQLi, an interpretable Q-learning framework for learning sequential SQL injection payload mutation strategies. SeqSQLi models WAF evasion as a Markov decision process in which the agent observes a discrete payload-response state, selects a grammar-aware mutation action, receives feedback from the target response, and updates a tabular Q-value [8]. The framework incorporates filter-aware exploration while preserving interpretability through learned state-action values

and successful mutation sequences.

This paper investigates whether SQL injection WAF evasion contains a measurable mutation-ordering signal. SeqSQLi is evaluated against random, fixed round-robin, single-heuristic, and filter-aware heuristic baselines using bypass success rate, interaction steps, learned Q-values, and successful mutation sequences. The contributions are: (1) a sequential decision formulation of SQL injection WAF evasion, (2) an interpretable Q-learning framework with filter-aware exploration and grammar-aware mutation actions, and (3) an analysis pipeline for studying mutation-ordering effects against non-learning baselines.

II. RELATED WORK

SQL injection detection has been widely studied because injection attacks remain a persistent threat to web application security. Traditional Web Application Firewalls rely on semantic rules, regular-expression matching, and handcrafted signatures to identify malicious requests, yet the flexibility of SQL syntax prevents rule libraries from covering all possible attack variants [1], [6]. Machine-learning and deep-learning approaches were introduced to address this limitation by transforming SQL queries into feature vectors, token sequences, graph representations, or learned embeddings before classification. Kar et al. proposed SQLiGoT, which represents SQL queries as graphs of tokens and applies SVM-based classification [3]. Kasim employed ensemble learning and regex-derived features to classify SQL injection attack levels [4]. Li et al. demonstrated that LSTM-based sequence modeling can detect SQL injection by learning contextual patterns from query strings [5]. These

methods improve static detection accuracy, but they still evaluate each payload as an isolated input rather than as the result of an adaptive mutation process.

The limitation of static SQL injection detection becomes more visible under adversarial payload transformation. A malicious SQL payload can preserve its attack semantics while changing its surface representation through keyword substitution, comment insertion, whitespace manipulation, function replacement, or syntax-level interference. WAF-A-MoLE demonstrated this setting by constructing a mutation-based adversarial framework for SQL injection payloads, where mutation rules generate variants that bypass Web Application Firewalls [2]. However, WAF-A-MoLE relies on a mutation tree and does not optimize multi-step strategy composition, which limits its ability to identify effective ordered combinations of transformations [6]. This distinction matters because the effect of one mutation depends on the payload state produced by earlier mutations. Replacing whitespace before inserting comments, for example, does not produce the same search trajectory as inserting comments before applying whitespace-level transformation.

Recent studies have applied reinforcement learning to web attack generation and WAF evasion. Wang and Han formulated WAF evasion as a reinforcement-learning problem and evaluated the framework on XSS and SQL injection payloads, but their method did not include grammar-aware SQL state representation or SQL-specific mutation design [9]. Amouei et al. proposed a reinforcement-learning-driven adaptive testing method for discovering bypass patterns in WAFs, although the method selects from existing clustered payloads rather than generating new SQL injection variants through

explicit mutation operators [10]. Hemmati and Hadavi explored deep reinforcement learning for WAF bypass using SQL injection action spaces, but their evaluation was limited to selected WAF systems such as ModSecurity-CRS, Naxsi, and WAF-Brain [11], [12]. These works show that reinforcement learning can improve adaptive attack generation, yet they do not directly analyze whether mutation ordering itself forms a measurable learning signal.

SSQLi is the closest work to the present study. Guan et al. proposed a black-box adversarial attack method for SQL injection based on reinforcement learning, using a state-vector representation algorithm, an attack-strategy matrix, and a Soft Actor-Critic agent to generate adversarial SQL injection examples [6]. Their attack-strategy matrix contains fourteen strategies grouped into syntactic transformation, syntactic-analysis interference, and semantic-analysis interference categories [6]. In their evaluation, SSQLi was tested against two WAFs and eight machine-learning or deep-learning detectors, achieving escape rates of up to 97.39% against LSTM and 96.37% against SVM detectors [6]. Despite this strong performance, SSQLi focuses on black-box adversarial example generation and detector degradation rather than isolating the role of mutation ordering. Its SAC-based framework learns to select attack strategies adaptively, but successful mutation sequences are not treated as the main object of analysis.

This gap motivates SeqSQLi. Prior work establishes that SQL injection detectors remain vulnerable to adversarial payload modification, that mutation-based systems can produce semantics-preserving variants, and that reinforcement learning can guide WAF evasion more effectively than unguided search. What

remains unresolved is whether SQL injection WAF evasion contains a repeatable mutation-ordering signal: a dependency structure in which one transformation becomes more effective because another transformation has already changed the payload state. SeqSQLi addresses this gap by modeling payload mutation as a sequential decision process using tabular Q-learning, where the agent observes a discrete payload-response state, selects a grammar-aware mutation action, receives feedback from the WAF-protected environment, and updates $Q(s,a)$ values [8]. Unlike prior adversarial SQLi frameworks that emphasize attack success alone, SeqSQLi evaluates whether learned mutation sequences reduce interaction steps and reveal interpretable ordering patterns compared with random, fixed round-robin, single-heuristic, and filter-aware heuristic baselines.

III. 대규모 추천 엔진을 위한 분산 그래프 데이터 저장 시스템

기존의 많은 추천 시스템들의 추천 기법들은 관계형 데이터베이스에 저장된 데이터들을 토대로 작동되었다. 그러나 테이블 간 조인 연산을 요구하는 관계형 데이터베이스는 추천 시스템의 성능 저하를 야기한다고 알려졌다[12]. 또한 방대한 양의 웹 데이터를 토대로 하는 추천 기법이 효과적으로 적용되기 위한 분산 그래프 데이터 저장 모델의 필요성이 증대되고 있지만 이와 관련된 연구는 아직 알려진 바가 없다. 따라서 본 논문에서는 그래프 데이터베이스 기반의 대규모 추천 엔진을 위한 분산 그래프 데이터 저장 시스템을 제안한다.

본 연구에서는 관련연구에서 소개된 Li-Young의 [00]에서 제안한 3개 층의 분산 저장구조를 확장하여 추천 시스템에 적합한 새로운 분산 저장 구조를 정의 한다. 즉, 소셜 컴퓨팅에 특화된 Li-Young의 분산 저장구조와 달리, 본 연구에서는 대규모 추천 시스템의 적합하게 작동될 수 있도록 유사 사용자 인텍스를 고안하여 분산 저장 시스템의 성능을 높

이고 각 파티션에 추천 엔진을 포함하였다.

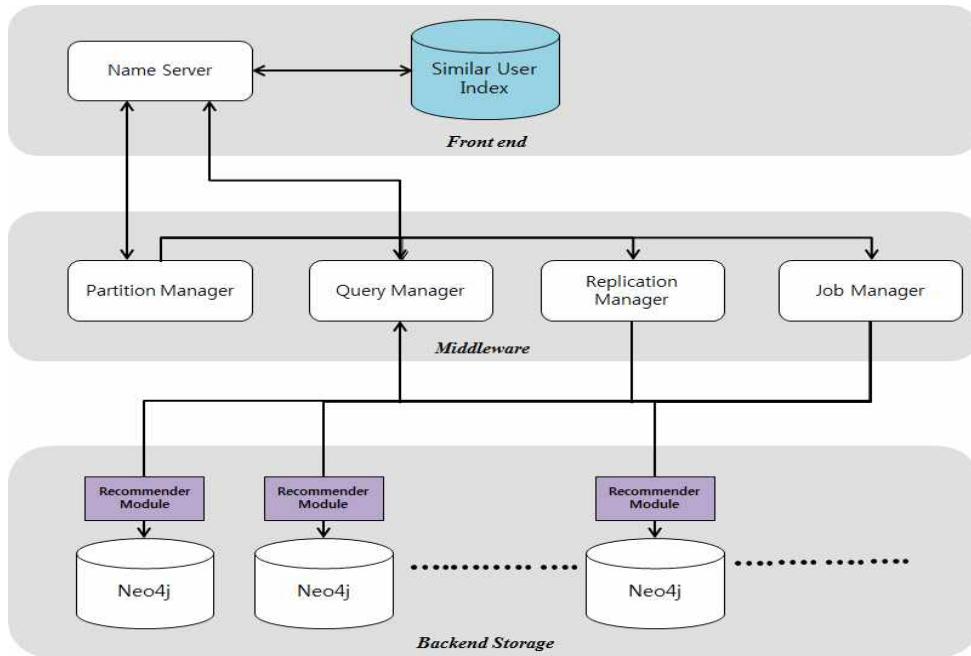


그림 1. 대용량 추천 시스템을 위한 분산 그래프 데이터 저장 시스템 구조

Fig. 1. Architecture of distributed graph data storage system for large-scale recommender systems

그림 1은 본 논문에서 제안하는 대규모 추천 엔진을 위한 분산 그래프 데이터 저장 모델 기반 시스템의 전체구조를 나타낸다. 전체 구조는 크게 세 개의 단계인 Front end, Middleware, 그리고 Backend Store로 구성된다. 먼저, Front end 단계는 사용자와의 인터페이스를 구현하는 단계로, name server와 유사 사용자 노드에 대한 색인인 유사 사용자 인덱스로 구성된다. name server는 사용자로부터 노드 아이디(Node identification)를 키워드로 하는 질의어를 전달받아 해당 질의어에 부합하는 노드들의 저장 위치를 similar user index로부터 가져온다. 유사 사용자 인덱스는 본 연구의 토대라 할 수 있는 [9]에서 제안된 색인기법으로 그래프 데이터베이스 기반의 추천 시스템의 성능을 보다 효과적으로 개선할 수 있음을 보였다.

그림 2는 [9]에서 제안된 유사 사용자 인덱스의 구조를 보인다. 유사 사용자 인덱스는 B-트리를 기반으로 구현되었으며 말단에는 각 특정 사용자 노드와 유사한 사용자 노드들의 노드 위치 정보가 저장 되어 있다. 협업 필터링 기법은 특정 사용자와

비슷한 성향을 가진 유사 사용자들을 기반으로 추천 목록을 구성한다. 전체 그래프에서 유사 사용자 노드들을 찾아 이를 따로 인덱스에 포함하기 위해 [9]에서는 협업 필터링 알고리즘을 분석하여 유사 사용자로 추출될 확률적 요소들을 정의하고 이를

그림, 표, 식과 글사이의 한줄을 띄웁니다.
그림과 표 안은 영문표기만 가능합니다.

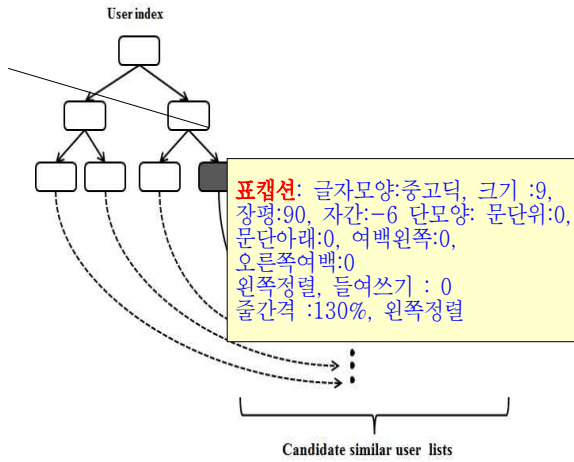


그림 2. 유사 사용자 색인

Fig. 2. Similar user index

표 1. 실험 데이터 세트

Table 1. Experimental data sets

Data type	User	Movie content	Evaluation points
Number of data			
2,000	1,500	500	54,032
4,000	3,000	1,000	84,000
6,000	4,000	2,000	354,003
8,000	5,000	3,000	754,004
9,940	6,040	3,900	1,000,209

표 1은 5개의 실험 데이터 세트를 보인다. 평가 점수는 사용자 A가 영화 콘텐츠 B에 대해 직접 부여한 평가 점수로 그래프 데이터베이스에서는 사용자 노드와 콘텐츠 노드의 관계를 구성하는 에지의 속성 값으로 나타낼 수 있다.

4.3 성능 평가

제안한 분산 그래프 데이터 저장 시스템의 성능 평가를 위해서 본 연구에서는 관계형 데이터베이스 기반의 추천 엔진과 제안 저장 시스템 기반의 추천 엔진을 구현하고 이들 각각의 추천 알고리즘의 수행 시간을 측정한다. 제안 기법과 RDB 기반의 추천 엔진의 성능은 매우 뚜렷한 차이를 보인다. 특히, 데이터의 크기가 커져감에 따라 RDB 기반의 추천 엔진 경우, 추천 항목 구성 시간도 비례하여 증가하는 반면, 제안 시스템 기반의 추천 엔진은 데이터 크기의 상관없이 비교적 일정한 추천 항목 구

성 시간이 걸리는 것을 보였다.

$$\hat{f}(x,y) = \text{median}_{(s,t) \in S_{xy}} \{g(s,t)\} \quad (1)$$

V. 결론 및 향후 과제

폭발적인 온라인 데이터의 증가는 원하는 정보를 얻고자하는 사용자와 이들 사용자를 대상으로 하는 사업자들에게 다양한 형태의 많은 불편함과 문제점들을 야기했다. 이러한 문제점들을 해소하기 위한 목적으로 등장한 다양한 형태의 추천 시스템들 역시 히스토리 데이터와 같은 저장하고 처리해야할 사용자 데이터가 증가함에 따라 성능이 저하되는 문제점에 직면하게 되었다.

본 논문에서는 대규모 추천 시스템의 추천 성능을 보다 효과적으로 높이기 위한 새로운 분산 그래프 데이터 모델을 제안하였다. 이를 위해 대량의 사용자 데이터를 처리함에 있어서 추천 항목에 대한 정확도를 유지하고 검색 시간을 단축하기 위해 새로운 형태의 유사 사용자 인덱스가 적용된 그래프 데이터 저장 시스템을 구현 하였다. 제안 시스템의 비교 성능 평가를 위해 관계형 데이터 베이스기반의 추천 엔진과 제안 시스템 기반의 추천 엔진을 각각 구현하고 추천 항목 구성 시간을 측정해 봄으로써 제안 시스템이 기존 관계형 데이터베이스보다 효과적으로 대규모 추천 엔진의 성능을 높일 수 있음을 보였다.

본 논문에서는 이전에 시도된 바 없던 대규모 추천 엔진을 위한 분산 그래프 데이터 모델을 제안 및 구현하고 추천 성능을 향상시킨다는 것을 입증하였다는 것을 증명하였다. 그러나 제안 시스템에서 적용된 파라메터 기반의 추천 알고리즘이 전체 시스템의 성능에 미치는 내용등과 관련한 실험이 이루어지지 않았다는 점과 기존 분산 그래프 데이터 저장 시스템들과의 적절한 비교 평가가 이루어지지 않았다는 점 등에서 본 연구의 한계를 찾을 수 있다. 따라서 이들 한계점을 극복하기 위한 연구를 본 논문의 향후 과제로 한다.

References

[1] OWASP Foundation, "A05:2025 - Injection," OWASP Top 10:2025. [Online]. Available: https://owasp.org/Top10/2025/A05_2025-Injection/. [accessed: Apr. 30, 2026].

[2] L. Demetrio, A. Valenza, G. Costa, and G. Lagorio, "WAF-A-MoLE: Evading Web Application Firewalls through Adversarial Machine Learning," Proc. 35th Annual ACM Symposium on Applied Computing, Brno, Czech Republic, pp. 1745-1752, Mar.-Apr. 2020.

[3] D. Kar, S. Panigrahi, and S. Sundararajan, "SQLiGoT: Detecting SQL injection attacks using graph of tokens and SVM," Computers & Security, Vol. 60, pp. 206-225, 2016.

[4] Ö. Kasim, "An ensemble classification-based approach to detect attack level of SQL injections," Journal of Information Security and Applications, Vol. 59, Article 102852, 2021.

[5] Q. Li, F. Wang, J. Wang, and W. Li, "LSTM-based SQL injection detection method for intelligent transportation system," IEEE Transactions on Vehicular Technology, Vol. 68, No. 5, pp. 4182-4191, May 2019.

[6] Y. Guan, J. He, T. Li, H. Zhao, and B. Ma, "SSQLi: A Black-Box Adversarial Attack Method for SQL Injection Based on Reinforcement Learning," Future Internet, Vol. 15, No. 4, Article 133, Mar. 2023. <https://doi.org/10.3390/fi15040133>.

[7] S. Al Wahaibi, M. Foley, and S. Maffei, "SQIRL: Grey-Box Detection of SQL Injection Vulnerabilities Using Reinforcement Learning," Proc. 32nd USENIX Security Symposium, Anaheim, CA, USA, pp. 4575-4592, Aug. 2023.

[8] R. S. Sutton and A. G. Barto, Reinforcement Learning: An Introduction, 2nd ed., Cambridge, MA, USA: MIT Press, 2018.

[9] X. Wang and H. Han, "Evading Web Application Firewalls with Reinforcement Learning," OpenReview, 2022. [Online]. Available: <https://openreview.net/forum?id=m5AntlhJ7Z5>. [accessed: Apr. 30, 2026].

[10] M. Amouei, M. Rezvani, and M. Fateh, "RAT:

Reinforcement-Learning-Driven and Adaptive Testing for Vulnerability Discovery in Web Application Firewalls," IEEE Transactions on Dependable and Secure Computing, Vol. 19, No. 5, pp. 3371-3386, Sept.-Oct. 2022.

[11] M. Hemmati and M. A. Hadavi, "Using Deep Reinforcement Learning to Evade Web Application Firewalls," Proc. 18th International ISC Conference on Information Security and Cryptology, Isfahan, Iran, pp. 35-41, Sept. 2021.

[12] M. Hemmati and M. A. Hadavi, "Bypassing Web Application Firewalls Using Deep Reinforcement Learning," ISeCure, Vol. 14, No. 2, pp. 131-145, 2022.

저자소개

홍 길 동 (Gil-Dong Hong)

사진

2xxx년 x월 : 한국대학교
전파공학과(공학사)
2xxx년 x월 : 한국대학교
전파공학과(공학석사)
2xxx년 x월 ~ 현재 :
(주)에이비씨텔레콤 연구원
관심분야 : 전력분배/결합기,

초고주파 발진기, CDMA 단말기 Hardware